

BDSEC JWT 'alg:none' Challenge Writeup

Summary

The application used a JWT stored in the **session** cookie for authentication. After logging in, the token contained: { "user": "guest", "role": "user" } Testing showed the server accepted a JWT with the header {"alg":"none"}, meaning it skipped signature verification. An unsigned token with the payload {"user":"admin","role":"admin"} was placed in the session cookie and sent to /admin, granting administrator access and revealing the flag.

Flag: bdsec{n0ne_4lg_m34ns_n0_s1gn4tur3}